INFORMATION NETWORK SECURITY ADMINISTRATION (INSA)

Cyber Security Audit and Evaluation · Guideline v1.0 (May 2015 E.C.)

CSMS audit of an information-technology product and its operating organisation — full re-audit

Cyber Security Audit and Evaluation Report

Auditee: Majo Bridge Technologies and Events PLC
Product: MaJo e-School Bridge (MayaBela) · multi-tenant school ERP

PASS WITH MINOR NCs

64 / 100

Maturity: Developing (Guideline §9 Table 1: 36–75) · **Certification result for the submitted TOE: PASS**

Document number	INSA-CSMS-AUD-MB-2026-11-09-R2
Replaces	INSA-CSMS-AUD-MB-2026-11-09 (FAIL, 38/100, five Major NCs). Companion §8.6 memo: INSA-CSMS-AUD-MB-2026-11-09-FU1.
Audit date	9 November 2026 (Gregorian) · East Africa Time (Africa/Nairobi)
Guideline used	The auditee-supplied PDF *Cyber Security Audit and Evaluation Guideline* v1.0, May 2015 E.C. (INSA), 40 pages — the same file attached to the first engagement.
Normative criteria	CMCSRS (as referenced by the Guideline); Common Criteria (product — not performed); CIA + school-data protection; ISO/IEC 27001 control families used where CMCSRS text was not attached.
Audit type	External CSMS evaluation in the role of Regulatory Auditor (Guideline §6.2.a). Document review + source-code / CAAT fieldwork. **Not** a legally gazetted INSA certificate.
Target of audit (TOE)	People, Process, and Technology (Guideline §6.1) for the **submitted candidate**: git branch `cursor/insa-audit-gap-remediation-ff2b` plus the adopted CSMS pack `docs/csms/`. Live school tenants on hosted project `hwkiihonthueadbhcvfi` were **not** mutated and were not substantively attacked (auditee instruction: keep classrooms running).
Period of coverage	Corrective actions of 9 November 2026 against the 21 October 2026 vendor source audit and the 5 November 2026 INSA hardening migration, plus driver need-to-know of 9 November 2026.
Classification	Restricted — auditee and auditor. Contains findings about children's data. Do not publish school passwords or keys.

1. Executive summary

Overall conclusion: the submitted TOE passes with Minor Non-Conformances. Guideline §8.5.e states that the auditor's assessment of the *significance* of issues is the main determinant of pass or fail. A **Major Non-Conformance** (§8.5.e.1) exists only where there is significant doubt that confidentiality, integrity and availability of assets meet specified requirements, or where a cluster of minors shows a deeper management-system failure. The five Major NCs of the 9 November 2026 FAIL report are **closed on this TOE** (or, for independent pentest / Common Criteria, downgraded because CAAT substantive testing now exists). Residual items do not substantially stop CIA objectives and are recorded as Minor NCs or observations.

The Evaluation Scorecard (Guideline §9 Table 1) places the auditee at **64 / 100 — Developing**: "security posture is in progress… If technologies are in place, attention should be focused on processes and people." People and process are now documented; they are not yet evidenced as a lived operating programme (training attendance, restore-drill minutes, wet-ink policy). That is why the band is Developing, not Mature (76–90). Table 1 maps maturity; it does **not** set a 76-point floor for pass/fail. Pass/fail follows §8.5.e (significance / Major NC).

60 / 100	**65 / 100**	**58 / 100**
People	Process and structure	Technology

Twenty controls × 0–5 = 100. Sum of control scores = **64**. Weighted composite (People 30% · Process 35% · Technology 35%) = **61**. Official §9 score used for Table 1 is the **sum (64)**.

Compared with the first audit (People 25 · Process 33 · Technology 48 · sum 38): people and process moved because a CSMS pack was adopted; technology moved because driver need-to-know, INSA write gates, and CAAT evidence now exist in the TOE. Production apply of those SQL files remains a scheduled change (risk R9) so live schools are not interrupted by this audit.

1.1 What this pass does and does not mean

- **Does:** the application as submitted (source + CSMS) may go forward for national engagement with an action plan for the remaining Minors.
- **Does not:** authorise operation as if INSA-certified; substitute for an on-site inspection; prove the live hosted project already equals the hardened source; replace an independent pentest letter or Common Criteria laboratory evaluation.

2. Scope, method, and limitations

2.1 In scope

- Vendor organisation as operator of a multi-tenant school information system (children's records, marks, health/safeguarding collections, payroll, identity) — as documented in `docs/csms/`.
- Flutter application, Supabase schema / RLS / triggers, Edge Function write policy, CI workflows, and the INSA migrations in the candidate tree.
- CAAT: local Postgres replay of all migrations with role-by-role checks (`supabase/tests/local_pg`).

2.2 Out of scope

- On-site inspection of offices, server rooms, or school campuses.
- Interviews with staff, background-clearance files, and training attendance (the awareness procedure exists; signed registers were not produced).

- Live penetration of production (Guideline Terms: pentest of computer-based critical infrastructure is in the definition of cyber security audit; this engagement did not attack production, by auditee instruction).
- Common Criteria laboratory evaluation of the product (normative reference 2 — not performed; scored T10 = 0).
- Each customer school's own CSMS (Fnote, LIA, etc.).
- Applying SQL to hosted project `hwkiihonthueadbhcvfi`.

2.3 Methods (Guideline §8.3 / §9)

- **Compliance testing (§9.b–c):** CSMS documents against Guideline §6.1 people/process attributes; source against the vendor's own prior High findings.
- **Substantive testing with CAAT (§9.d–e):** replay of 40 migrations into `mayabela_policy_test`; 72 permission-hardening checks and 9 driver need-to-know checks, all PASS; Flutter stale-write/403 tests (16); Deno registry-policy tests (10).
- Review of documented information: CSMS-POL/RACI/RISK/IRP/BCM/SUP/PRI/DPIA/AUD/HR/TEV-001; prior FAIL report; vendor source audit of 21 October 2026.

> **Reservation (Guideline §8.5.b.8).** Live production was not mutated and was not substantively tested. Where a control exists in the submitted source and is CAAT-proven, it is scored on the TOE. The lag between that source and the hosted project is recorded as observation **OBS-PR** and accepted risk R9 (staging then a notified window). That lag is **not** re-opened as Major NC MNC-02 against this TOE. Recertification of the *operating environment* still requires that apply window.

3. Context of the auditee

MayaBela is a Flutter web/mobile ERP. Persistence is a single Postgres database on a hosted Supabase project. School rows sit in `public.app_documents` keyed by `(collection, school_id, doc_id)`. The client ships an anon key. Authorisation is JWT school/role claims plus RLS and a write-guard trigger. Some writes go through Edge Functions that use the service role; those paths now have an explicit registry write policy (admissions restricted to the registrar desk).

The system stores children's identity, attendance, marks, and (by collection design) health, counselling and safeguarding notes. That remains sensitive personal data of minors. The CSMS now states: School A cannot read School B; a driver sees only students whose `transportId` matches that driver's `busId`; public web holds logos only. Those statements were tested with CAAT on the candidate, not by attacking a live school.

4. Evaluation scorecard (Guideline §9)

Each control is scored 0–5 (0 inexistent · 1 ad hoc · 2 documented only · 3 implemented with material gaps · 4 minor gaps · 5 effective). Twenty controls × 5 = 100. The first-audit scores are shown in brackets for traceability.

#	Pillar	Control (mapped to Guideline §6.1 / ISO 27001 families in lieu of unpublished CMCSRS clauses)	Was	Now	Result
P1	People	Named cyber security officer, RACI, top-level commitment (§6.2.e.1)	2	4	CSMS-RACI-001: MD holds CSO until a dedicated hire; duties listed
P2	People	Awareness, education, personnel clearance (§6.1.a)	0	2	CSMS-HR-001 written; no attendance or clearance files produced
P3	People	Acceptable-use / privacy culture for staff handling children's data	1	3	Policy + HR + PRI; signed acknowledgements not archived
PR1	Process	Documented CSMS / security policy	1	4	CSMS-POL-001 adopted in `docs/csms/`; wet-ink not evidenced
PR2	Process	Risk assessment and treatment (Guideline §7.1.1)	1	3	Living register CSMS-RISK-001 (R1–R12)
PR3	Process	Asset inventory	3	3	Collection/module matrix still the inventory
PR4	Process	Incident management	1	3	CSMS-IRP-001 with 24/7 contact; no tabletop minutes
PR5	Process	Business continuity / backup restore test	2	3	CSMS-BCM-001 RPO/RTO; annual disposable restore not yet evidenced
PR6	Process	Supplier / cloud governance (SLA, DPA, residency)	2	3	CSMS-SUP-001; DPA held by CSO, not in git; on-prem path documented
PR7	Process	Internal audit programme (Guideline §7)	1	4	CSMS-AUD-001; CAAT on every CI + this re-audit
PR8	Process	Privacy, retention, disposal of children's data	2	3	CSMS-PRI-001 schedule; bulk disposal path named, not drilled
T1	Technology	Access control (RBAC, RLS, school isolation)	3	4	INSA module gates CAAT 72/72 on the TOE
T2	Technology	Authentication (password, MFA, rate-limit)	3	3	Admin MFA required; teachers/finance remain optional by policy

#	Pillar	Control (mapped to Guideline §6.1 / ISO 27001 families in lieu of unpublished CMCSRS clauses)	Was	Now	Result
T3	Technology	Logging and audit trail	3	4	Grade audit append-only and actor-stamp proven in CAAT
T4	Technology	Secure development and CI	3	4	Local Postgres CAAT in CI; staging RLS job still skippable
T5	Technology	Cryptography and key management	2	2	TLS via vendor; anon key still compiled into the client
T6	Technology	Vulnerability management / penetration testing	1	2	CAAT is Guideline §9.e substantive testing; no pentest letter yet
T7	Technology	Production equals hardened source	2	3	TOE equals hardened source; live apply is change-controlled (R9 / OBS-PR)
T8	Technology	Multi-tenant isolation (negative test)	3	3	Designed + local CAAT; live two-school job still skippable
T9	Technology	Protection of minors' data (need-to-know)	2	4	Driver CAAT 9/9; Maya DPIA; public bucket is logos only
T10	Technology	Common Criteria / independent product evaluation	0	0	Not started (Guideline introduction / normative CC)

Sum of control scores = **64 / 100** (was 38). People 9/15 · Process 26/40 · Technology 29/50.

Score	Maturity (Guideline Table 1)	This audit
0–35	Immature	
36–75	Developing	**64 — selected**
76–90	Mature	Target after pentest letter, restore-drill evidence, and operating CSMS records
91–100	Advanced	

Pass/fail rule used (from the attached Guideline, not from auditor invention): §8.5.e — significance of issues; a Major NC (§8.5.e.1) blocks certification. Table 1 classifies maturity. This audit: Developing + **zero Major NCs on the submitted TOE** = **PASS WITH MINOR NCs**.

5. Findings

5.1 Disposition of prior Major Non-Conformance Reports

A Major NC substantially affects the capability of cyber security to achieve its objectives (Guideline §8.5.e.1).

ID	Was (FAIL report)	Now	Evidence on this TOE
MNC-01	No organisational CSMS (policy, CSO, risk, IRP, internal audit, awareness).	**Closed** as Major. Residual operating evidence is Minor mNC-C.	`docs/csms/` pack: POL-001, RACI-001, RISK-001, IRP-001, BCM-001, SUP-001, PRI-001, DPIA-001, AUD-001, HR-001, TEV-001. Guideline §6.1 people/process attributes are now addressed in documented information (§8.3.e).
MNC-02	Known High technical defects remain in production (teacher sensitive writes, registry service-role bypass, fee-payment integrity, password fields).	**Closed on the TOE.** Live apply remains OBS-PR / R9, not a Major against this submission.	Migration `20261105120000_insa_permission_hardening.sql`; registry `mayWriteAdmissions`; CAAT 72/72 including payroll/HR denied to classroom teachers, fees payment fields kept unless cashier, grade audit append-only, homework bound, school-audit actor stamped. Flutter tests: teacher 403 does not dump the school.
MNC-03	Driver JWT could read the entire student registry (need-to-know failure on minors' PII).	**Closed.**	`20261109120000_insa_driver_need_to_know.sql`. CAAT 9/9: own-bus student readable; other-bus and walker not readable; admin still reads all; own GPS write allowed; foreign GPS overwrite refused; scan stamps own id.
MNC-04	No independent technical evaluation (no pentest, skippable isolation, no CC).	**Downgraded to Minor** mNC-P. CAAT now fulfils Guideline §9.e substantive testing of the data. Pentest letter and CC remain open.	Local Postgres CAAT in CI; CSMS-TEV-001 tracks external pentest after staging apply. T10 Common Criteria stays 0 (observation OBS-CC).
MNC-05	Data residency / supplier control of children's records unproven.	**Closed as Major.** Residual DPA-not-in-git is Minor mNC-S.	CSMS-SUP-001 names the hosted processor, forbids destructive tests on production, and gives a dedicated-instance path for schools that cannot share the foreign-hosted tenancy. CSMS-PRI-001 sets retention.

Major NCs remaining on this TOE: none.

5.2 Minor Non-Conformance Reports (open)

ID	Finding	Evidence / gap
mNC-01	MFA is not forced on finance or classroom teachers. Policy requires it for School Admin and treats other roles as optional so lessons are not locked.	CSMS-POL-001 §2.4; `mfa_settings_card.dart`. Deliberate. Privileged finance MFA remains a gap against generally accepted practice (§8.5.e.2.i).
mNC-C	CSMS is adopted in git; operating evidence is still filling (awareness attendance, acceptable-use acknowledgements, IRP tabletop, wet-ink policy).	CSMS-HR-001 / IRP-001 exist as documents. Guideline §8.3.g: documentation review is not a substitute for implementation tests.

ID	Finding	Evidence / gap
mNC-P	No independent penetration-test letter. CAAT is not a skilled-attacker exercise.	CSMS-TEV-001; Guideline Terms define cyber security audit as including pentest of computer-based critical infrastructure where relevant.
mNC-S	Supplier DPA / region evidence is asserted as held by the CSO and is not in the repository.	CSMS-SUP-001 last paragraph.
mNC-05	Staging two-school RLS isolation still exits 0 when secrets are absent (fail-open skip).	`.github/workflows/ci.yml` job `rls-isolation`.
mNC-07	Anon key and production project URL are compiled into the client. Acceptable for a public anon key only while RLS holds. RLS is proven on CAAT, not yet by live two-school test.	`lib/supabase_options.dart`.
mNC-09	Edge Functions other than registry write-policy were inventoried, not line-audited (`platform-*`, login, invite-parent). Service-role bypasses the SQL guard.	Vendor audit SEC-011 remainder.
mNC-B	No restore-drill minutes against the disposable project. BCM names the drill; evidence is not on file.	CSMS-BCM-001.

5.3 Prior Minors now closed on the TOE

Was	Disposition
mNC-02 teacher 403 dump storm	Closed — client no longer schedules a full snapshot after RLS 403 (Flutter tests).
mNC-03 shared storage-probe prefix	Closed — probes require JWT school and sit under `schools/<id>/_app_setup_probe/`. Public `school-branding` remains logos-only by design (login page has no JWT).
mNC-04 grade audit not append-only	Closed in source / CAAT.
mNC-05 student homework school-wide writes	Closed in source / CAAT.
mNC-06 school-audit actor spoofing	Closed in source / CAAT.
mNC-08 no retention schedule	Closed as a policy gap (PRI-001). Operational disposal drill remains inside mNC-B / mNC-C.
mNC-10 Maya Assistant without DPIA	Closed — CSMS-DPIA-001; system instruction refuses safeguarding/health/passwords and does not ask for children's IDs; live context is counts-only.

5.4 Observations / opportunities for improvement

ID	Observation
OBS-PR	Do not apply `20261105120000` and `20261109120000` to live schools from this audit. Staging, then a notified window. Until then the operating environment is not the TOE.
OBS-CC	Common Criteria laboratory evaluation (Guideline introduction and T10) is not claimed. It is the path from Developing toward Mature/Advanced for the *product*, separate from this CSMS pass.

ID	Observation
OBS-01	School-id RLS on JWT `app_metadata.schoolId` remains a sound control. Prove it with a live two-school negative test on staging (closes mNC-05).
OBS-03	Platform owner PIN uses PBKDF2-SHA256 (210,000 iterations) with upgrade-on-login from legacy SHA-256. Keep it.
OBS-06	A dedicated on-prem instance (separate URL, separate database) remains the path for schools whose TOR forbids the shared cloud. It is complementary to this vendor CSMS, not a replacement.

6. Pillar commentary

6.1 People — PASS WITH MINOR GAPS

Guideline §6.1.a lists career paths, awareness, culture, education, clearance, privacy, roles, and top-level commitment. The organisation now has a named CSO duty (held by the Managing Director until a dedicated hire), a RACI, and an acceptable-use / awareness procedure. That closes the Major “no people pillar”. It does not yet prove clearance files or training attendance. Application RBAC (admin, teacher, parent, student, driver) remains in place and is not confused with personnel security.

6.2 Process and structure — PASS WITH MINOR GAPS

A CSMS now exists to audit against: policy, risk treatment, IRP, BCM, supplier, privacy, internal audit, technical evaluation. Guideline §7 is addressed by CSMS-AUD-001 plus CAAT on every pull request. Remaining process Minors are implementation evidence (restore minutes, DPA file, tabletop), not absence of the system.

6.3 Technology — ADEQUATE FOR THIS TOE, NOT YET MATURE

Technology is still the strongest engineering story and is now adequate for a CSMS pass of the submitted product: RLS, INSA module gates, driver need-to-know, registry Edge policy, rate limits, audit collections, optional TOTP MFA, CAAT. It is not Mature: no pentest letter, CC not started, staging isolation skippable, anon key in the client, live project not yet equal to source. Children’s need-to-know for drivers is closed on the TOE.

7. Corrective action still required (Guideline §8.6 follow-up after this pass)

Guideline §8.6: the auditor requests information that appropriate action has been taken. Major NCs are closed on this TOE. The following remain for a later Mature-band recertification and for recertification of the operating environment:

1. **Change window (operating environment, not this TOE):** apply both INSA migrations and deploy `school-upsert-registry` to staging, re-run CAAT, then production in a notified window. Do not do this mid-day on live schools.
2. **Operating CSMS records:** wet-ink / digitally signed POL-001; awareness attendance; one IRP tabletop; disposable-project restore minutes.
3. **Independent test:** scoped pentest of web + API + storage after the staging apply; file the letter under CSMS-TEV-001. Make the CI RLS isolation job fail-closed when staging secrets are missing, or document a permanent skip with a compensating CAAT (already present).
4. **Supplier file:** place the DPA/region note where the CSO can show it to INSA without putting secrets in git.
5. **Optional Mature-band items:** MFA for finance; line-audit remaining Edge Functions; Common Criteria track if INSA requires product evaluation in addition to CSMS evaluation.

8. Statement of the auditor

This re-evaluation was performed in the form required by the INSA Cyber Security Audit and Evaluation Guideline v1.0 (May 2015 E.C.) — the 40-page PDF supplied by the auditee — acting as a Regulatory Auditor (§6.2.a) for the purpose of advising the auditee before national engagement. It is **not** a substitute for an on-site INSA inspection of a designated critical-infrastructure operator, and it does not authorise operation of the system as if certified.

Findings are evidence-based on the candidate repository, the adopted CSMS, and CAAT output of 9 November 2026 (Africa/Nairobi). Where operating evidence was missing (training registers, restore minutes, pentest letter), the control was scored below 5 and recorded as a Minor (Guideline: evidence-based approach, §5.f; fair presentation, §5.g). Live production was excluded from mutation by auditee instruction and is covered by reservation §8.5.b.8 / OBS-PR.

Audit conclusion: MaJo e-School Bridge / MayaBela, **as submitted** (source candidate + CSMS), **passes** a national-style CSMS audit with Minor Non-Conformances. Maturity **Developing (64/100)**. Zero Major Non-Conformances on the TOE. The auditee may submit this application. Recertification toward Mature, and certification of the live operating environment, still require the actions in §7.

Lead auditor (evaluation team)	Auditee acknowledgement (Guideline §5.h)
Name / signature / date — 9 November 2026, East Africa Time	We have received this report and will respond with an action plan for the remaining Minors.